

ASICI

Asociación Internacional
de Ciberseguridad



Manual básico para interpretar auth.log de Linux

1. ¿Qué es el **auth.log**?

El archivo **auth.log** es un registro de seguridad de sistemas Linux, especialmente en distribuciones basadas en Debian y Ubuntu.

Normalmente se encuentra en:

`/var/log/auth.log`

En otras distribuciones, como CentOS, RHEL, Rocky Linux o AlmaLinux, información similar suele encontrarse en:

`/var/log/secure`

El **auth.log** registra eventos relacionados con:

- Autenticación de usuarios
- Inicios de sesión SSH
- Uso de sudo
- Cambios de usuario con su
- Sesiones abiertas y cerradas
- Intentos fallidos de acceso
- Usuarios inválidos
- Escalamiento de privilegios
- Eventos PAM
- Tareas programadas con cron

Es uno de los logs más importantes para detectar ataques contra servidores Linux.

2. Tipo de log

El **auth.log** usa un formato basado en **syslog**.

Ejemplo:

May 2 10:15:23 ubuntu-server sshd[2456]: Failed password for invalid user admin from 185.220.101.45 port 50222 ssh2

Estructura general:

MES DÍA HORA HOSTNAME PROCESO[PID]: MENSAJE

Ejemplo descompuesto:

Campo	Ejemplo	Significado
Mes	May	Mes del evento
Día	2	Día del evento
Hora	10:15:23	Hora local del servidor
Hostname	ubuntu-server	Nombre del equipo
Proceso	sshd	Servicio que generó el evento
PID	2456	Identificador del proceso
Mensaje	Failed password...	Detalle del evento

3. Formato de una línea **auth.log**

Ejemplo 1: login fallido por SSH

May 2 10:15:23 ubuntu-server sshd[2456]: Failed password for invalid user admin from 185.220.101.45 port 50222 ssh2

Campo	Valor
Fecha	may 2
Hora	10:15:23
Servidor	ubuntu-server
Servicio	sshd
PID	2456
Evento	Failed password
Usuario	admin
IP origen	185.220.101.45

Puerto origen	50222
Protocolo	ssh2

Ejemplo 2: login exitoso por SSH

May 2 10:20:44 ubuntu-server sshd[2501]: Accepted password for maurice from 203.0.113.10 port 44321 ssh2

Interpretación:

El usuario maurice inició sesión correctamente por SSH desde la IP 203.0.113.10.

Ejemplo 3: uso de sudo

May 2 10:25:01 ubuntu-server sudo: maurice : TTY=pts/0 ; PWD=/home/maurice ; USER=root ; COMMAND=/usr/bin/apt update

Interpretación:

El usuario maurice ejecutó un comando con privilegios de root usando sudo.

4. Servicios comunes que aparecen en **auth.log**

Servicio	Qué registra
sshd	Accesos remotos por SSH
sudo	Ejecución de comandos privilegiados
su	Cambio de usuario
pam_unix	Autenticación mediante PAM
CRON	Tareas programadas
systemd-logind	Apertura y cierre de sesiones

<code>passwd</code>	Cambios de contraseña
<code>useradd</code>	Creación de usuarios
<code>userdel</code>	Eliminación de usuarios
<code>groupadd</code>	Creación de grupos
<code>chsh</code>	Cambio de shell
<code>login</code>	Inicios de sesión locales

5. Mensajes importantes que debes aprender

5.1 Eventos SSH

Mensaje	Significado	Lectura de seguridad
<code>Accepted password</code>	Login exitoso con contraseña	Normal, revisar IP y usuario
<code>Accepted publickey</code>	Login exitoso con llave pública	Normal, método más seguro
<code>Failed password</code>	Login fallido	Puede ser error o ataque
<code>Invalid user</code>	Usuario inexistente	Fuerte indicador de enumeración
<code>Connection closed</code>	Conexión cerrada	Puede ser normal o escaneo
<code>Connection reset</code>	Conexión reiniciada	Puede indicar escaneo automatizado

maximum authentication attempts exceeded	Demasiados intentos	Posible fuerza bruta
Did not receive identification string	Cliente no completó handshake SSH	Reconocimiento o escaneo
PAM service(sshd) ignoring max retries	Reintentos PAM	Posible abuso de autenticación

Mensaje	Significado	Lectura de seguridad
Accepted password	Login exitoso con contraseña	Normal, revisar IP y usuario
Accepted publickey	Login exitoso con llave pública	Normal, método más seguro
Failed password	Login fallido	Puede ser error o ataque
Invalid user	Usuario inexistente	Fuerte indicador de enumeración
Connection closed	Conexión cerrada	Puede ser normal o escaneo

Connection reset	Conexión reiniciada	Puede indicar escaneo automatizado
maximum authenticat ion attempts exceeded	Demasiados intentos	Posible fuerza bruta
Did not receive identifica tion string	Cliente no completó handshake SSH	Reconocimien to o escaneo
PAM service(ss hd) ignoring max retries	Reintentos PAM	Posible abuso de autenticación

5.2 Eventos sudo

Mensaje	Significado	Lectura de seguridad
COMMAND=	Comando ejecutado con sudo	Revisar si el comando es esperado
authentica tion failure	Fallo usando sudo	Puede indicar intento de escalar privilegios
incorrect password attempts	Contraseña incorrecta para sudo	Sospechoso si se repite

user NOT in sudoers	Usuario sin permisos intentó sudo	Intento de privilegios no autorizados
TTY=unknown	Comando sin terminal interactiva	Revisar automatización o script

5.3 Eventos su

Mensaje	Significado	Lectura de seguridad
session opened for user root	Cambio exitoso a root	Revisar usuario origen
session closed for user root	Cierre de sesión root	Normal si corresponde
authentication failure	Fallo al usar su	Intento fallido de cambio de usuario
FAILED SU	Cambio de usuario fallido	Sospechoso si se repite

5.4 Eventos de usuarios

Mensaje	Significado	Lectura de seguridad
new user	Usuario creado	Revisar autorización
delete user	Usuario eliminado	Revisar cambio administrativo

password changed	Contraseña cambiada	Normal o sospechoso según contexto
add user to group	Usuario agregado a grupo	Crítico si es sudo, admin, root, docker
remove user from group	Usuario removido de grupo	Revisar si fue autorizado

6. Campos clave para análisis de seguridad

6.1 Fecha y hora

Ejemplo:

May 2 10:15:23

Permite identificar:

Ataques por ventanas de tiempo

Intentos repetidos

Secuencia del incidente

Correlación con access.log, firewall, EDR o SIEM

6.2 Hostname

Ejemplo:

ubuntu-server

Ayuda a saber en qué servidor ocurrió el evento.

En ambientes grandes es importante correlacionar:

Servidor web

Servidor de base de datos
Servidor de aplicaciones
Jump server
Servidor de administración

6.3 Proceso

Ejemplo:

`sshd[2456]`

El proceso indica qué servicio generó el evento.

Procesos críticos:

`sshd`
`sudo`
`su`
`passwd`
`useradd`
`userdel`
`groupadd`
`cron`
`systemd-logind`

6.4 Usuario

Ejemplo:

`invalid user admin`

El usuario permite detectar:

Cuentas atacadas
Cuentas inexistentes
Uso de cuentas privilegiadas
Intentos contra root
Cuentas de servicio usadas indebidamente

Usuarios que merecen atención:

`root`
`admin`
`administrator`

test
oracle
postgres
mysql
ubuntu
user
guest
support
backup

6.5 IP origen

Ejemplo:

from 185.220.101.45

Es clave para detectar:

Fuerza bruta SSH
Password spraying
Origen geográfico anómalo
IPs repetitivas
Escaneos automatizados
Conexiones desde proveedores cloud

6.6 Puerto origen

Ejemplo:

port 50222

Normalmente es un puerto efímero del cliente. No suele ser tan importante como la IP, pero sirve para trazabilidad.

7. Tabla de eventos frecuentes

Evento en auth.log	Significado	Riesgo
Accepted password for user	Login SSH exitoso	Bajo si es esperado
Accepted publickey for user	Login SSH con llave	Bajo si es esperado
Failed password for user	Contraseña incorrecta	Medio si se repite
Failed password for invalid user	Usuario inexistente	Alto si se repite
Invalid user	Intento contra usuario inexistente	Alto
maximum authentication attempts exceeded	Demasiados intentos	Alto
Did not receive identification string	Conexión incompleta	Medio
sudo: COMMAND=	Uso de privilegios	Depende del comando
user NOT in sudoers	Usuario intentó sudo sin permiso	Alto
authentication failure	Fallo de autenticación	Medio
session opened for user root	Sesión root abierta	Alto si no es esperado
new user	Usuario creado	Alto si no fue

		autorizado
delete user	Usuario eliminado	Alto si no fue autorizado
password changed	Cambio de contraseña	Medio/alto
cron	Tarea programada	Revisar persistencia

8. Cómo identificar ataques en **auth.log**

8.1 Fuerza bruta SSH

Indicadores:

Muchos Failed password
Misma IP origen
Mismo usuario o múltiples usuarios
Intervalo corto de tiempo

Ejemplo:

```
May 2 10:10:01 server sshd[2001]: Failed password for root from 185.220.101.45 port 50100 ssh2
May 2 10:10:04 server sshd[2002]: Failed password for root from 185.220.101.45 port 50101 ssh2
May 2 10:10:07 server sshd[2003]: Failed password for root from 185.220.101.45 port 50102 ssh2
```

Interpretación:

Probable ataque de fuerza bruta contra la cuenta root.

8.2 Enumeración de usuarios

Indicadores:

Invalid user
Failed password for invalid user
Muchos nombres distintos de usuario
Misma IP origen

Ejemplo:

```
May 2 11:01:10 server sshd[2100]: Invalid user oracle from 198.51.100.20
May 2 11:01:12 server sshd[2101]: Invalid user postgres from 198.51.100.20
May 2 11:01:14 server sshd[2102]: Invalid user backup from 198.51.100.20
```

Interpretación:

El atacante intenta descubrir usuarios válidos en el servidor.

8.3 Password spraying

A diferencia de la fuerza bruta tradicional, el password spraying intenta una misma contraseña contra muchos usuarios.

Indicadores:

- Muchos usuarios diferentes
- Pocos intentos por usuario
- Misma IP o bloque de IPs
- Eventos Failed password
- Ventanas de tiempo cortas

Ejemplo lógico:

```
IP 203.0.113.80 prueba acceso contra:
admin
oracle
postgres
backup
deploy
test
```

Interpretación:

Probable password spraying.

8.4 Intentos contra root

Indicadores:

- Failed password for root
- Accepted password for root
- session opened for user root
- su: session opened for user root

Ejemplo:

May 2 12:15:44 server sshd[2300]: Failed password for root from 185.10.10.10 port 55120 ssh2

Interpretación:

Intento directo de acceso privilegiado.

Recomendación defensiva:

Deshabilitar login SSH directo como root.
Usar usuarios nominales y sudo controlado.

8.5 Uso sospechoso de sudo

Indicadores:

Comandos inusuales
Uso fuera de horario
Usuario no habitual
Ejecución de herramientas de red o transferencia
Fallas repetidas de sudo

Ejemplo:

May 2 13:22:01 server sudo: maurice : TTY=pts/0 ; PWD=/tmp ; USER=root ;
COMMAND=/usr/bin/nano /etc/sudoers

Interpretación:

El usuario modificó, o intentó modificar, una configuración sensible de privilegios.

Comandos que merecen revisión:

Comando	Motivo
/bin/bash	Shell privilegiada
/usr/bin/passwd	Cambio de contraseña
/usr/sbin/useradd	Creación de usuarios

<code>/usr/sbin/usermod</code>	Cambio de permisos
<code>/bin/chmod</code>	Cambio de permisos
<code>/bin/chown</code>	Cambio de propietario
<code>/usr/bin/curl</code>	Descarga externa
<code>/usr/bin/wget</code>	Descarga externa
<code>/usr/bin/nc</code>	Comunicación de red
<code>/usr/bin/python</code>	Ejecución de scripts
<code>/usr/bin/crontab</code>	Persistencia

8.6 Usuario no autorizado intentando sudo

Ejemplo:

```
May 2 14:05:12 server sudo: www-data : user NOT in sudoers ; TTY=pts/1 ;
PWD=/var/www/html ; USER=root ; COMMAND=/bin/bash
```

Interpretación:

Muy sospechoso. Un usuario del servicio web intentó ejecutar una shell como root.

Esto podría estar relacionado con:

Explotación de aplicación web

Web shell

Movimiento lateral

Escalamiento de privilegios

8.7 Creación de usuarios sospechosa

Ejemplo:

```
May 2 15:10:33 server useradd[3101]: new user: name=backup2, UID=1003, GID=1003,
home=/home/backup2, shell=/bin/bash
```

Interpretación:

Se creó un nuevo usuario. Debe verificarse si fue autorizado.

Indicadores de riesgo:

Usuario creado fuera de horario
Usuario con nombre parecido a uno legítimo
Usuario agregado luego al grupo sudo
Usuario con shell interactiva

8.8 Agregado a grupo privilegiado

Ejemplo:

```
May 2 15:12:01 server usermod[3110]: add 'backup2' to group 'sudo'
```

Interpretación:

El usuario backup2 fue agregado al grupo sudo. Esto le da capacidad de elevar privilegios.

Grupos sensibles:

sudo
admin
root
wheel
docker
lxd
adm
shadow

8.9 Búsqueda de persistencia vía cron

Ejemplo:

```
May 2 16:00:01 server CRON[4001]: pam_unix(cron:session): session opened for user root  
by (uid=0)
```

Este evento puede ser normal. Pero debe revisarse cuando aparece junto con:

Cambios recientes en crontab
Comandos sospechosos
Conexiones externas
Usuarios nuevos
Uso de wget, curl, bash o python

9. Tabla resumen de ataques y señales

Ataque	Señales en auth.log
Fuerza bruta SSH	Muchos Failed password desde una IP
Enumeración de usuarios	Muchos Invalid user con usuarios distintos
Password spraying	Muchos usuarios atacados con pocos intentos cada uno
Ataque contra root	Failed password for root o Accepted password for root
Escalamiento de privilegios	Uso sospechoso de sudo, su, COMMAND=/bin/bash
Abuso de cuenta de servicio	www-data, mysql, postgres intentando sudo
Creación de usuario malicioso	useradd, new user fuera de contexto
Persistencia	Cambios en usuarios, grupos o cron
Movimiento lateral	Logins exitosos desde IPs internas no habituales
Robo de credenciales	Accepted password desde país/IP no esperada
Uso indebido de llaves SSH	Accepted publickey desde origen no habitual

10. Ejemplos de líneas normales

Login exitoso por llave SSH

May 2 09:10:22 server sshd[1200]: Accepted publickey for maurice from 203.0.113.10 port 42110 ssh2: RSA SHA256:abc123

Interpretación:

Acceso remoto exitoso mediante llave pública.

Uso normal de sudo

May 2 09:12:01 server sudo: maurice : TTY=pts/0 ; PWD=/home/maurice ; USER=root ;
COMMAND=/usr/bin/apt update

Interpretación:

El usuario ejecutó una actualización del sistema con privilegios.

Cierre de sesión

May 2 09:30:14 server sshd[1200]: pam_unix(sshd:session): session closed for user
maurice

Interpretación:

La sesión SSH del usuario fue cerrada.

11. Ejemplos de líneas sospechosas

Ataque contra usuario inexistente

May 2 10:01:11 server sshd[2201]: Failed password for invalid user admin from
185.220.101.45 port 50122 ssh2

Señales:

Usuario inexistente
IP externa
Fallo de contraseña

Demasiados intentos de autenticación

May 2 10:03:15 server sshd[2220]: error: maximum authentication attempts exceeded for
root from 185.220.101.45 port 50144 ssh2 [preauth]

Señales:

Demasiados intentos
Usuario root
Fase preauth

Usuario de servicio intentando sudo

May 2 11:20:33 server sudo: www-data : user NOT in sudoers ; TTY=unknown ;
PWD=/var/www/html ; USER=root ; COMMAND=/bin/bash

Señales:

Usuario www-data
Intento de sudo
Comando /bin/bash
Directorio web

Interpretación:

Posible explotación de una aplicación web con intento de escalar privilegios.

Login exitoso después de múltiples fallos

```
May  2 12:00:01 server sshd[3001]: Failed password for deploy from 198.51.100.40 port 50101 ssh2
May  2 12:00:05 server sshd[3002]: Failed password for deploy from 198.51.100.40 port 50102 ssh2
May  2 12:00:09 server sshd[3003]: Accepted password for deploy from 198.51.100.40 port 50103 ssh2
```

Interpretación:

El acceso exitoso posterior a varios fallos puede indicar compromiso de credenciales.

12. Consultas recomendadas con Pandas

Cuando parsees `auth.log`, conviene extraer estas columnas:

```
datetime
month
day
time
hostname
process
pid
event_type
username
source_ip
source_port
auth_method
command
```

status
is_attack
attack_type

Consultas útiles:

Top IPs con más fallos SSH
Top usuarios atacados
Usuarios inválidos más frecuentes
Intentos contra root
Logins exitosos por IP
Logins exitosos después de fallos
Eventos sudo por usuario
Comandos sudo más usados
Usuarios que intentaron sudo sin permiso
Eventos por hora
Ataques por tipo
IPs con más eventos sospechosos

13. Lógica simple de detección

13.1 Detección de fuerza bruta

Si una IP genera muchos Failed password en poco tiempo, entonces puede ser fuerza bruta.

Ejemplo de regla:

Más de 10 fallos SSH desde la misma IP en 5 minutos.

13.2 Detección de enumeración de usuarios

Si una IP prueba muchos usuarios inexistentes, entonces puede estar enumerando cuentas.

Ejemplo de regla:

Más de 5 usuarios inválidos diferentes desde una misma IP en 10 minutos.

13.3 Detección de sudo sospechoso

Si un usuario no autorizado intenta sudo, o ejecuta comandos críticos,

entonces debe investigarse.

Ejemplo de regla:

Usuario www-data ejecuta sudo o intenta COMMAND=/bin/bash.

13.4 Detección de compromiso de cuenta

Si hay muchos fallos y luego un login exitoso desde la misma IP, entonces puede haber credenciales comprometidas.

Ejemplo de regla:

5 Failed password para el mismo usuario/IP y luego Accepted password.

14. Buenas prácticas defensivas

Riesgo	Medida recomendada
Fuerza bruta SSH	Fail2Ban, bloqueo por firewall, MFA
Ataques contra root	Deshabilitar PermitRootLogin
Contraseñas débiles	Usar llaves SSH y políticas robustas
Exposición de SSH	Restringir por VPN o IP autorizada
Uso indebido de sudo	Revisar /etc/sudoers y aplicar mínimo privilegio
Usuarios sospechosos	Auditoría periódica de /etc/passwd y grupos
Falta de monitoreo	Enviar logs a SIEM
Poca retención	Configurar rotación y retención adecuada
Ataques distribuidos	Correlación por ASN, país, reputación e IP

15. Relación con otros logs

El `auth.log` debe correlacionarse con:

Log	Uso
<code>access.log</code>	Ver si una explotación web antecedió un intento de sudo
<code>error.log</code>	Revisar errores de aplicación o servidor web
<code>syslog</code>	Eventos generales del sistema
<code>kern.log</code>	Eventos del kernel
<code>audit.log</code>	Auditoría avanzada de comandos y archivos
logs de firewall	Bloqueos y conexiones
logs EDR/XDR	Procesos, archivos y comportamiento
logs SIEM	Correlación centralizada

Ejemplo de correlación:

1. `access.log` muestra explotación contra `/upload.php`
2. `auth.log` muestra `www-data` intentando sudo
3. `syslog` muestra ejecución de proceso extraño
4. firewall log muestra conexión saliente

Interpretación:

Posible compromiso de aplicación web con intento de escalamiento y comunicación externa.

16. Conclusión

El `auth.log` es una fuente fundamental para detectar ataques contra servidores Linux. A diferencia de `access.log`, que muestra actividad web, `auth.log` revela intentos de autenticación, uso de privilegios, sesiones y cambios de usuarios.

Para interpretar correctamente este log, se debe analizar:

Quién intentó acceder
 Desde qué IP
 A qué usuario
 Con qué resultado

Cuándo ocurrió
Qué servicio lo generó
Qué comando se ejecutó
Si hubo elevación de privilegios

Las señales más importantes son:

Failed password
Invalid user
Accepted password
Accepted publickey
sudo COMMAND
user NOT in sudoers
session opened for user root
new user
add user to group sudo

Un analista debe aprender primero a leer líneas individuales, luego agrupar eventos por IP, usuario y tiempo con Pandas, y finalmente aplicar visualización, correlación y detección automática de anomalías.